

codeserver-1.0.0-dev-0.0.3

codeserver-1.0.0-dev-0.0.3

Revision: 1 · **Last modified:** 2026-07-01T00:00:00Z

Third dev pre-release of **HelixCode**. This round pivots authentication to a **real-account, SSH-key challenge-response** model: a HelixCode session runs **host-native as the real host user** (default `milosvasic`) — natively inheriting that user's `~/.ssh` keys, full `.bashrc`, and every host binary — and the login screen proves control of one of the account's SSH keys by having the user sign a fresh server-issued challenge. **No password exists anywhere; nothing is stored.** The editor Explorer defaults to `PROJECTS_ROOT` as a convenience view (honestly **not** a security jail). The design supersedes the earlier live-PAM-login draft, which is impossible as a non-root service on this ALT/tcb host (captured facts, §11.4.6).

Authoritative sources: pivot spec <docs/superpowers/specs/2026-07-01-auth-pivot-ssh-key.md>, user guide <docs/guides/AUTH.md>, feature ledger <docs/features/Status.md>.

Feature — real-account SSH-key login

- **Sessions tied to the real host account (milosvasic).** code-server runs **host-native as that user**, so the editor session **natively** has the real user's identity and environment — nothing copied or synced:
 - **~/.ssh keys** — every key the account already registered with Git services works for git-over-SSH straight from the integrated terminal.
 - **Full .bashrc / profile** — the terminal spawns a login shell (`bash -l`), so exported vars, `PATH` additions, and init steps are all present.
 - **All host binaries / utilities** — every tool the user normally has.

- **SSH-key challenge-response login (no password, nothing stored).**
 1. GET /login issues a **fresh 32-byte nonce**, HMAC-signed by the server and bound to a short TTL (unforgeable, non-replayable), and shows the exact local command to run.
 2. The user signs it locally: `printf %s '<challenge>' | ssh-keygen -Y sign -n helixcode-login -f ~/.ssh/id_ed25519` — the **private key never leaves the user's machine**.
 3. The signature is pasted back (POST /login → { principal, signature }).
 4. The gate verifies the challenge is server-issued + unexpired, then runs `ssh-keygen -Y verify -n helixcode-login -f <allowed_signers> -I <principal> -s <sig>` where <allowed_signers> is derived from the account's ~/.ssh/authorized_keys. Success → a __Host--prefixed signed session cookie; failure → generic 401, rate-limited.
- **Nothing stored — anywhere.** No password parameter, no stored password: not in the repo, config, env, logs, or captured evidence (§11.4.10). The gate reads only the account's public authorized_keys; it never reads a private key.
- **Editor Explorer defaults to PROJECTS_ROOT — a convenience view, NOT a jail (§11.4.6).** The integrated terminal, **File > Open Folder**, tasks, the debugger, and extensions retain **full real-user (milosvasic) host-filesystem access by design** — there is no code-server flag that confines the process to PROJECTS_ROOT. Real isolation would need a container / VM / chroot (out of scope per operator decision).

Architecture

Host-native editor + auth behind a containerized TLS edge:

```

Browser —HTTPS→ Caddy (TLS edge, CONTAINERIZED, rootless
Podman)
                    |— forward_auth → helix-auth (host-native,
systemd --user, loopback:8081, NON-root)
                    |— reverse_proxy → code-server (host-native
AS milosvasic, systemd --user,
                                --auth none,
loopback:8080)
                                inherits ~/.ssh,
~/.bashrc, all host binaries
                                workspace =
PROJECTS_ROOT (Explorer default view, NOT a jail)

```

- **code-server** — host-native systemd --user service, --auth none, bound to loopback 127.0.0.1:8080 (auth is enforced entirely at the gate/edge).

- **helix-auth** — host-native systemd --user **Gin** gate, loopback 127.0.0.1:8081, non-root. Runs the challenge/verify flow, issues + validates the session cookie, **fails closed**.
- **Caddy TLS edge** — the only containerized component (rootless Podman, §11.4.76 / §11.4.161). Terminates TLS, gates every request via forward_auth to helix-auth's GET /auth (valid cookie → proxy to code-server; otherwise denied — **never bypassed on gate failure**), speaks **HTTP/3 (QUIC)**, compresses responses (encode zstd br gzip) via a **custom xcaddy-brotli** image, **blocks** /proxy with 403, and **strips the X-Helix-User header** from client requests so only the gate can set it.

Stack directive

This release adopts, for the auth surface: **Go + Gin (gin-gonic)** for the gate, **HTTP/3 (QUIC)** at the Caddy edge, and **Brotli** response compression (via a custom xcaddy build). These are the sanctioned building blocks for the authentication + edge stack going forward.

Security hardening (independent review + research)

Findings from an independent code review + security research, all addressed:

- **CVE-2026-35414 “SplitSSHell” closed** — the verified principal is now **server-pinned** (the client cannot smuggle a mismatched / attacker-chosen principal past ssh-keygen -Y verify).
- **Rate-limiter DoS fixed** — keying on the **rightmost X-Forwarded-For** entry (the real client IP behind the single trusted Caddy hop), **counting only after CSRF validation**, a **per-client spawn ceiling** on verify subprocesses, and **stale-entry purging** so the limiter map cannot be flooded into exhaustion.
- **__Host- session cookie** — __Host- prefix + SameSite=Strict + Secure + HttpOnly, with **session regeneration** on login (no fixation).
- **CSRF double-submit** protection on the login POST.
- **Key-type allow-list** — DSA keys, cert-authority lines, and weak/short RSA keys are **rejected** from the allowed-signers set.
- **Exec / temp hygiene** — signature material handled via securely-created temp files, cleaned up on every path; subprocess invocation hardened.

- **OpenSSH version floor** — a minimum ssh-keygen version is required so the -Y sign / -Y verify semantics the gate relies on are present.

Testing (§11.4.169)

Full test-type matrix covering the new auth surface:

- **Go layer** — unit / integration / race suites for the helix-auth gate: **70 tests**, run with -race, **81.8% coverage**.
- **Shell suites** (tests/types/): e2e_auth, security_auth, stress_chaos_auth, concurrency_auth, load_auth, memory_auth, benchmark_auth, challenges_auth, helixqa_auth — plus the HelixQA banks tests/banks/helixcode-auth-challenges.yaml and tests/banks/helixcode-auth-helixqa.yaml.
- Autonomous, no-operator, no-password evidence path (§11.4.98): tests generate a challenge, sign it with the real key via ssh-keygen -Y sign, POST it → expect 302 + cookie; tampered signature / non-authorized key / replayed challenge → expect 401 — all with captured evidence.

LIVE VALIDATION AGGREGATE (release-gate run, this host, real id_ed25519 key): full §11.4.169 matrix = 23/23 suites PASS, 0 FAIL (evidence root qa-results/run_all/20260701T151300Z-3182121). Auth surface green LIVE against the deployed stack: e2e_auth 5/5, security_auth 5/5, challenges_auth 5/5, concurrency_auth 5/5, helixqa_auth 4/0/1, load_auth 3/0/1, memory_auth 2/2, benchmark_auth 4/4, stress_chaos_auth 5/0/1 (live kill+recover of the gate and code-server, fail-closed verified) — plus unit 5/5, race 2/2 (-race), load 3/3. The 10 legacy prior-release suites (integration, e2e, security, tls_letsencrypt, full_automation, concurrency, memory, benchmark, helixqa, challenges) test the RETIRED container+password model and now report an honest **SKIP** (topology_unsupported, “superseded by <name>_auth”) — no false-FAIL (§11.4.1). Go gate tests: **70 tests, -race, 81.8% coverage**. Full end-to-end edge journey proven: browser → HTTPS :52443 (Caddy HTTP/3 + Brotli) → forward_auth ssh-key gate → host-native code-server → editor loads (login 303 → authed 200, X-Helix-User: milosvasic).

Honest boundaries (§11.4.6)

- **Editor “jail” is cosmetic.** The Explorer defaults to PROJECTS_ROOT, but the terminal / Open Folder / extensions keep full real-user host access by design — this is a convenience view, not a security boundary.
- **--auth none on loopback:8080 residual.** code-server itself runs unauthed on loopback; all auth is at the gate/edge. If a local process on the host reaches 127.0.0.1:8080 it bypasses the

gate — a **host firewall rule** restricting loopback:8080 is recommended and documented.

- **code-server pinned to 4.117.0** (the newest on npm at release time).
- **Real, publicly-trusted Let's Encrypt is operator-gated** — it needs a public domain + reachable :80/:443 or a DNS-01 token (LAN box); the ACME machinery is proven against a local CA (see docs/guides/TLS.md).

Migration

- **Install:** scripts/install-auth.sh (host-native, **no sudo**) provisions the systemd --user code-server + helix-auth units; deploy/up.sh brings up the containerized Caddy edge.
- **CODE_SERVER_PASSWORD is retired.** The single-password model is gone. Replacement parameters (see deploy/.env.example / docs/guides/AUTH.md): HELIX_AUTH_MODE=sshkey, HELIX_AUTH_ACCOUNT, HELIX_AUTH_AUTHORIZED_KEYS, HELIX_AUTH_PRINCIPAL, PROJECTS_ROOT. There is **no password parameter**.